CNOVI PROGRAMACIÓN WAP

Reporte laboratorio #7: Path Traversal Simple Case



Lizeth Infante Martínez

Reporte de Laboratorio: Path Traversal Simple Case

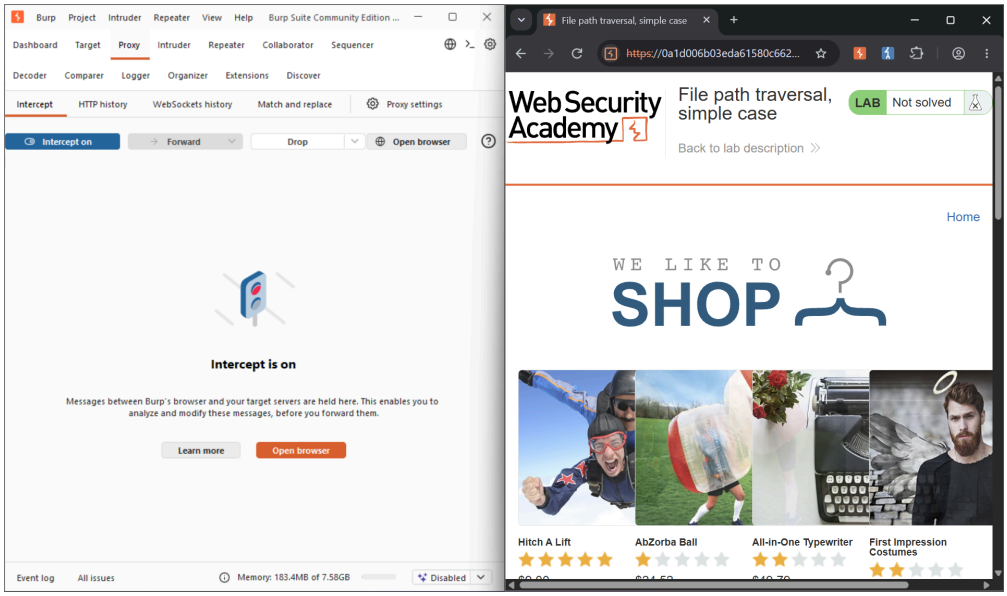
1. Objetivo

Demostrar la vulnerabilidad de salto de directorio (Path Traversal) en una aplicación web mediante la manipulación del parámetro filename en solicitudes HTTP, utilizando Burp Suite para interceptar, modificar y reenviar peticiones con el fin de acceder a archivos restringidos del servidor (como /etc/passwd).

2. Metodología y Pasos de Resolución

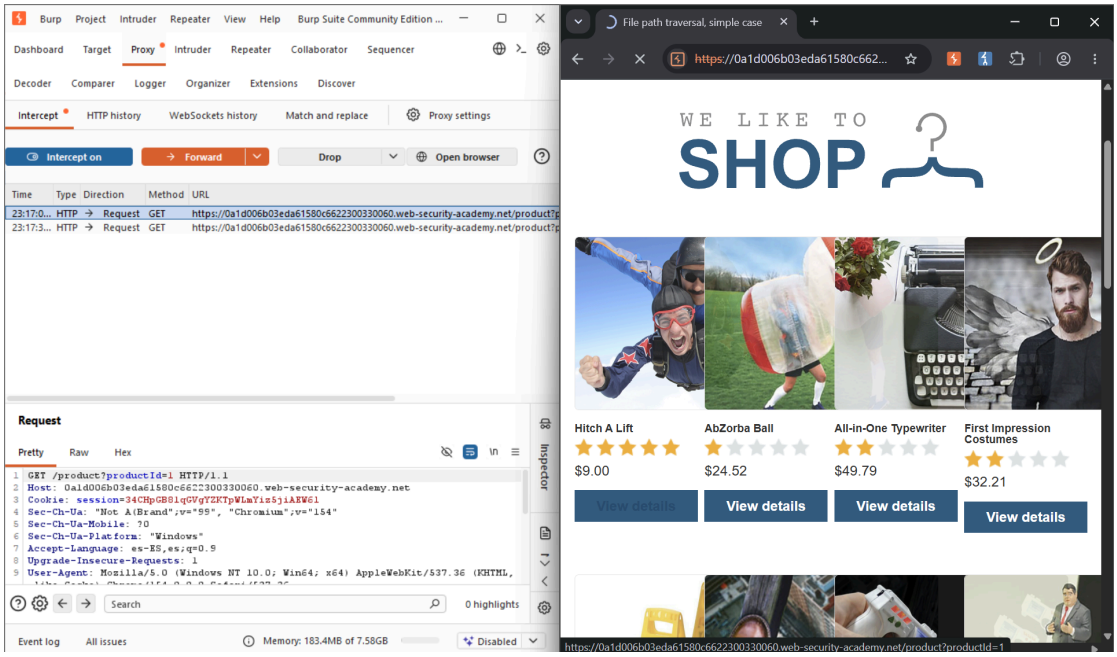
Paso 1: Configurar la intercepción en Burp Suite

- Ve a la pestaña Proxy en Burp Suite y asegúrate de que el botón indique Intercept on (Interceptación activada).



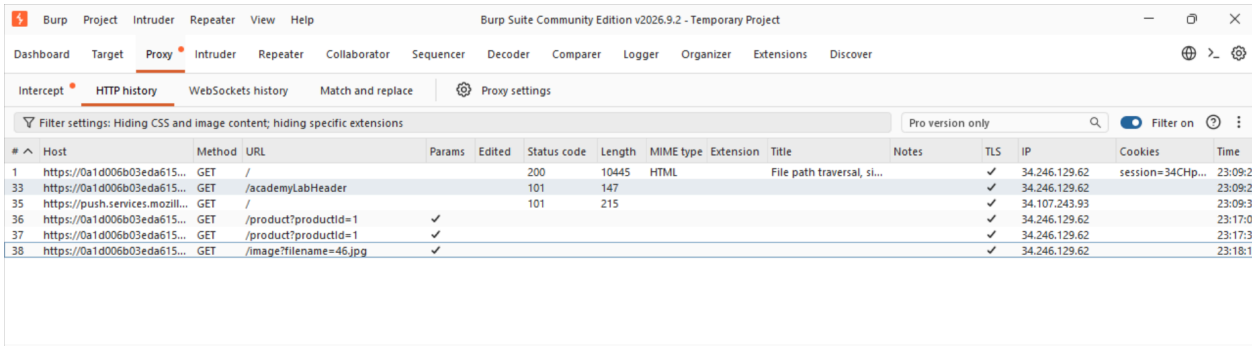
Paso 2: Generar la petición de una imagen de producto

- Dirígete a la ventana del navegador integrada en Burp o a tu navegador configurado con el proxy.
- Haz clic en cualquiera de los productos de la tienda (por ejemplo, "Hitch A Lift" o cualquier otra imagen) para ver los detalles o cargar una imagen.

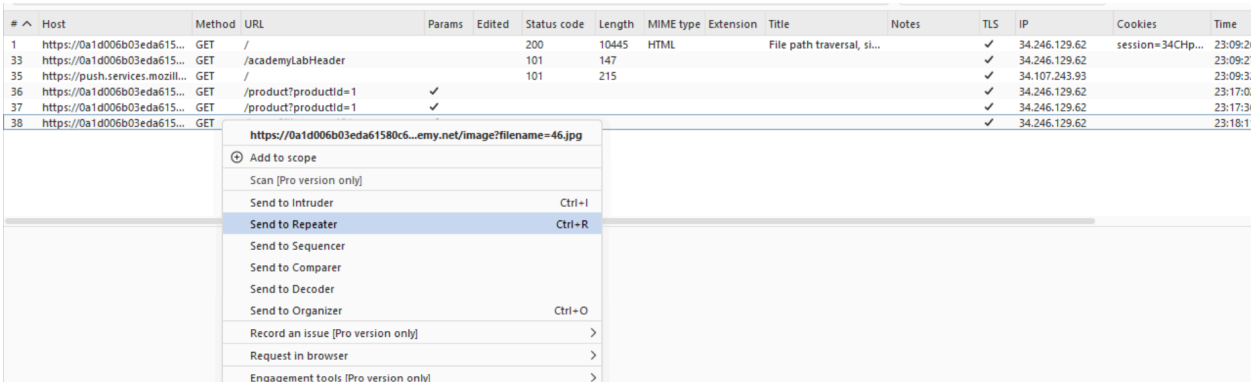


Paso 3: Interceptar, modificar la solicitud y usar el Repeater

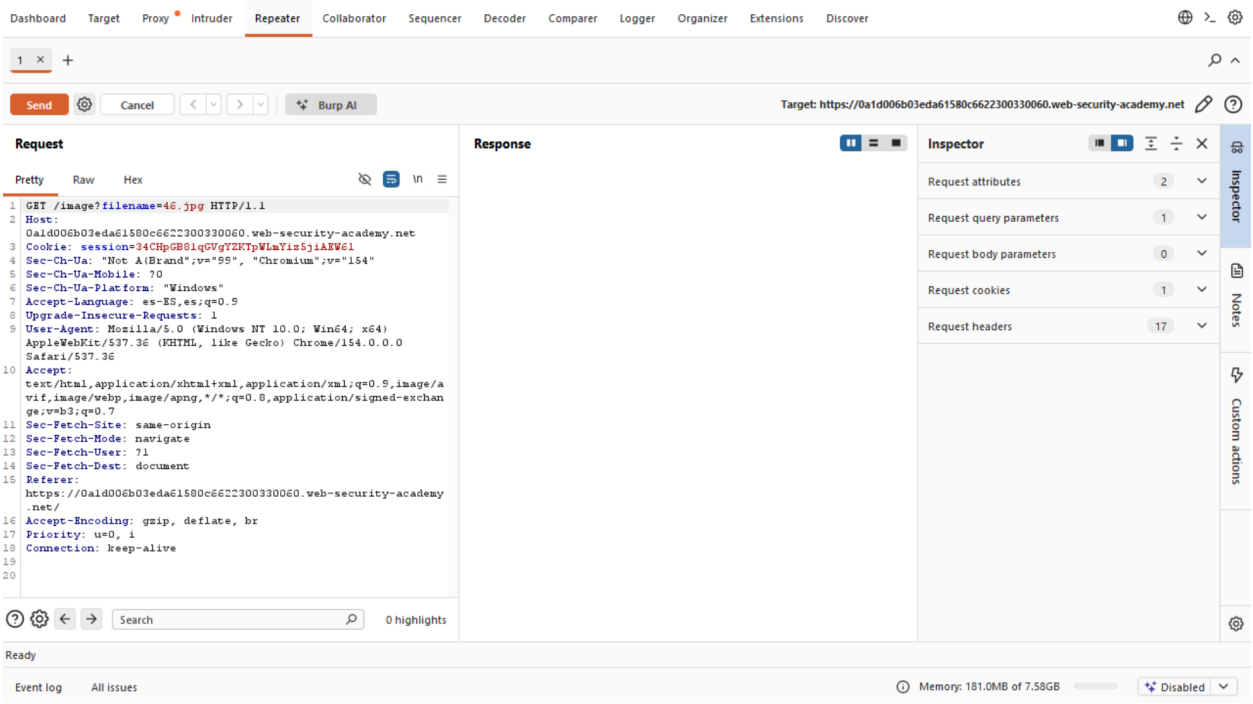
La petición se pausará en Burp Suite en la pestaña Proxy > Intercept. Verás una solicitud HTTP que incluye un parámetro llamado filename= (el cual especifica el nombre de la imagen que se está cargando).



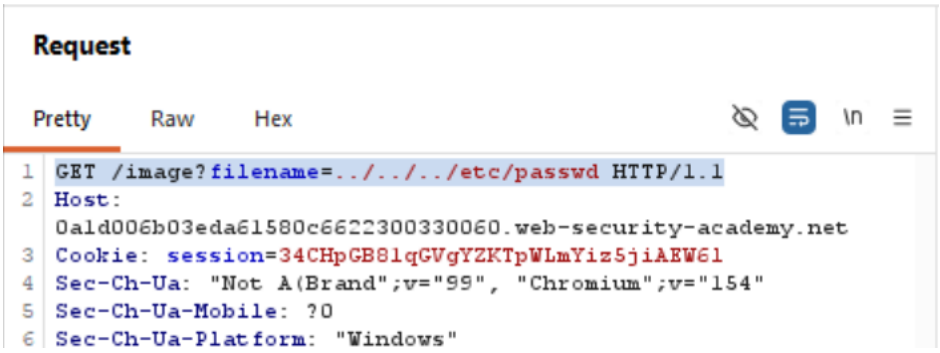
En la lista de HTTP history, haz clic derecho sobre la petición correspondiente (por ejemplo, GET /image?filename=46.jpg) y selecciona Send to Repeater



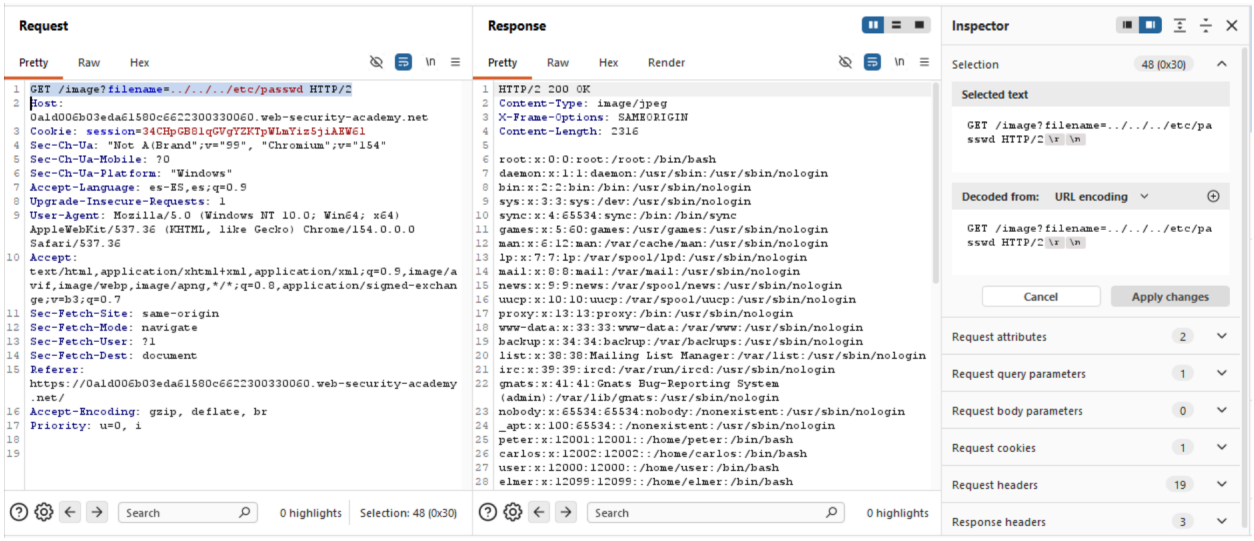
Abre la pestaña Repeater en el menú superior de Burp Suite.
En el panel de la petición HTTP, ubica la primera línea y cambia el nombre de la imagen por la ruta de manipulación de archivos:



GET /image?filename=../../../etc/passwd HTTP/1.1



Haz clic en el botón Send en la esquina superior izquierda de la pestaña Repeater.



3. Verificación y Resultados

- **Panel de Respuesta (Repeater):** Al enviar la petición modificada, revisa el panel de respuesta (*Response*). Deberías observar el contenido del archivo /etc/passwd (líneas de texto que comienzan con usuarios como root:x:0:0...), lo que confirma que la vulnerabilidad existe y que el laboratorio se marcará como resuelto.
- **Navegador:** Si realizaste la modificación vía Proxy, al volver a la pestaña del navegador del laboratorio verás que la página muestra ahora el contenido interno del archivo /etc/passwd del servidor, completando y resolviendo el laboratorio con éxito.

